MDCA session control: OneDrive on unmanaged devices

How to deliberately produce the Defender for Cloud Apps monitored-access notice ('Access to ... is monitored') and the download-blocked message for users on unmanaged devices: licensing, defining a managed device, a Conditional Access policy with Conditional Access App Control, Defender for Cloud Apps session policies filtered by device, file extension and sensitivity label, user messages, the SharePoint app-enforced alternative, the gaps it leaves, testing and rollback. Documentation verified against Microsoft Learn; not lab-tested.

8 phases | 22 steps | Tick each item when its "done when" criterion is true

Phase 1 Understand the two messages users see about 30–60 minutes

- [ ] **1.1 The monitored-access notice**
  Team can explain that the notice comes from Defender for Cloud Apps user monitoring after a Conditional Access policy applied Conditional Access App Control
- [ ] **1.2 The download-blocked message**
  Team can explain that the block comes from a session policy with Block action (or the built-in Block downloads) and where its message text is configured
- [ ] **1.3 Trace a real event in the logs**
  For one test sign-in you have the Entra sign-in log entry showing the Conditional Access policy with App Control, and the matching Defender for Cloud Apps activity

Phase 2 Licensing and choosing the right control about 1–2 hours

- [ ] **2.1 Confirm licensing from the service description**
  Every user in scope has a Defender for Cloud Apps entitlement and Entra ID P1 (or a plan that includes them); Purview entitlement confirmed if you plan to use Protect/labels
- [ ] **2.2 Choose session control, app-enforced restrictions, or both**
  Decision record states which control protects which data, for which users, and why
- [ ] **2.3 If you choose the SharePoint route: allow limited, web-only access**
  Access control > Unmanaged devices set to 'Allow limited, web-only access' (or per-site via PowerShell) and 'Apps that don't use modern authentication' blocked

Phase 3 Define what a managed device is about Half a day (if Intune or hybrid join already exists)

- [ ] **3.1 Use Intune compliance or Microsoft Entra hybrid join as the signal**
  Defender portal > Settings > Cloud apps > Device identification shows Intune compliant and hybrid joined identification configured; a managed test device appears with the right Device tag in the activity log
- [ ] **3.2 Make browsers on managed devices send device identity**
  Test sign-in from a managed device in each supported browser shows the device as compliant/hybrid joined in the Entra sign-in log
- [ ] **3.3 Optional: identify managed devices with client certificates**
  Root or intermediate CA (.pem) uploaded under Device identification; test device with user-store certificate shows Device tag Valid client certificate

Phase 4 Route unmanaged browser sessions with Conditional Access about 1–2 hours

- [ ] **4.1 Create the Conditional Access policy**
  Policy exists with pilot group, break-glass excluded, Office 365 targeted, Browser client app, device filter for unmanaged devices and Session > Use Conditional Access App Control
- [ ] **4.2 Pick Monitor only, Block downloads or Use custom policy**
  Choice documented: built-in option for a quick start, or Use custom policy with named Defender for Cloud Apps session policies

Phase 5 Block the .zip download and write the messages about 1–3 hours

- [ ] **5.1 Create a session policy that blocks .zip downloads on unmanaged devices**
  Session policy 'Block .zip download – unmanaged – OneDrive/SharePoint' is enabled with Device tag does not equal managed tags, App = OneDrive for Business + SharePoint Online, Extension = zip, Action = Block

- [ ] **5.2 Write a block message that guides instead of just stopping**
  Custom block message names the reason, offers an alternative and a contact; reviewed by someone outside IT
- [ ] **5.3 Optional: label-based block, Protect on download, or step-up**
  If used, policies for sensitivity-label block or Protect are scoped and tested; step-up uses an Entra authentication context
- [ ] **5.4 Configure the monitored-access notice and Edge for Business settings**
  User monitoring notification on with reviewed custom text; Edge for Business protection setting chosen and documented

Phase 6 Close the gaps session control does not cover about Half a day to 2 days

- [ ] **6.1 Block desktop, sync and mobile clients on unmanaged devices**
  Second Conditional Access policy for Mobile apps and desktop clients requires a compliant or hybrid joined device for the same users; optional Defender for Cloud Apps access policy blocks Mobile and desktop
- [ ] **6.2 Block legacy authentication and restrict 'Anyone' links**
  Legacy authentication blocked by Conditional Access; 'Anyone' links disabled or restricted on sites in scope
- [ ] **6.3 Be honest about what remains possible**
  Risk register lists residual paths: screenshots/photos, manual retyping, copy/paste and print unless separately blocked, previews in the browser, guests from other tenants

Phase 7 Pilot, test and communicate about 1–2 weeks pilot

- [ ] **7.1 Run the test matrix with a pilot account**
  Matrix completed: unmanaged Edge (work profile), unmanaged Chrome, managed device, InPrivate, sync client, Office desktop app, mobile; results match expectations
- [ ] **7.2 Tell users before you widen the scope**
  Short notice sent to affected users and service desk briefed with a written description of both messages, the reason and the self-service path

Phase 8 Troubleshooting and rollback about As needed

- [ ] **8.1 Work through the common failure modes**
  Runbook covers misidentified devices, missing App Control option, app not listed, network/TLS errors, slow sign-ins and default behaviour
- [ ] **8.2 Roll back narrowly**
  Rollback steps documented and rehearsed: Conditional Access policy to Off/Report-only, session policy disabled, scope group reduced

Owner	Change / ticket	Date completed

Original checklist by Tenant Recipes, an independent project not affiliated with Microsoft or any vendor. Every step, its actions, pitfalls and the official sources it was checked against are on https://tenantrecipes.com/guides/mdca-session-control-unmanaged-devices.html. Time estimates are our own planning figures. Confirm against the linked sources and test in a pilot before production.